Cryptographic Basics

Dr Om Pal, Associate Professor
Dept of Computer Science,
University of Delhi

The Objectives of Cryptography

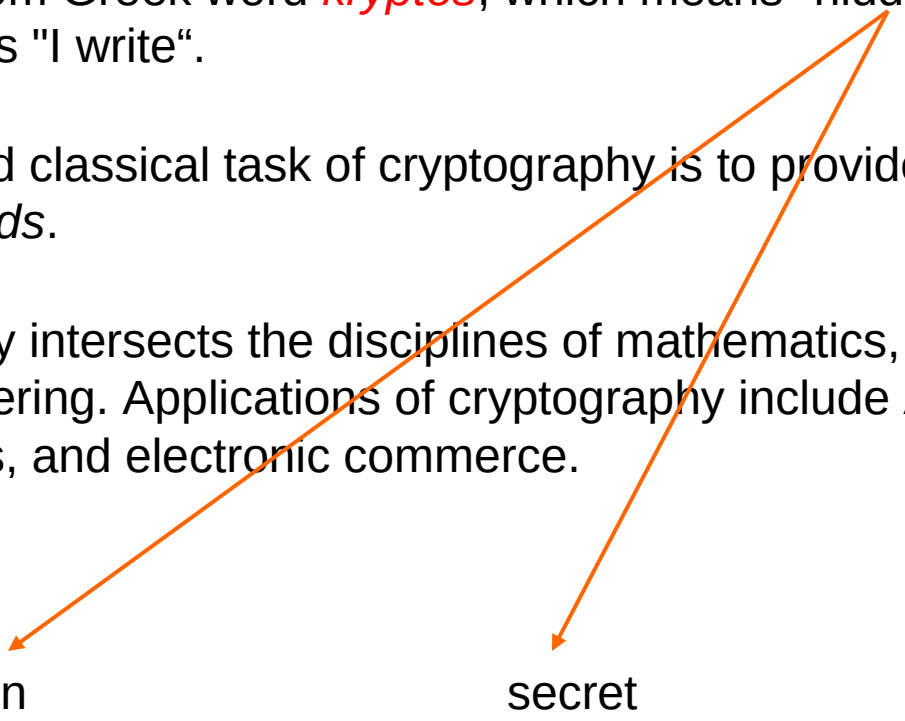
What is Cryptography:

Cryptography is the science of keeping secrets secret.

Cryptography is from Greek word *kryptos*, which means "hidden, secret"; and *gráphō*, which means "I write".

The fundamental and classical task of cryptography is to provide *confidentiality* by *encryption methods*.

Modern cryptography intersects the disciplines of mathematics, computer science, and engineering. Applications of cryptography include ATM cards, computer passwords, and electronic commerce.



The Objectives of Cryptography

Steganography and Cryptography:

Steganography is the art and science of communicating in a way which **hides the existence** of the communication. As an example, it is possible to embed a text inside an image or an audio file.

On the other hand, cryptography is the study of **mathematical techniques related to aspects of information security** such as confidentiality, data integrity, entity authentication, and data origin authentication.

Steganography

- In a digital message, the secret information is inserted or "hidden" into the “container data” <any type of digital data file>
- It doesn’t appear to be anything other than what it is eg. A picture or music file.
- An encrypted file on the other hand cries out *‘I contain sensitive information!!!*’
- Computer files (images, sounds recordings, even disks) contain unused or insignificant areas of data.
- Steganography takes advantage of these areas, replacing them with information.

Steganography: AN Example

- Hiding the message among irrelevant data
- To Confuse the cryptoanalyst

Steganography: AN Example

- Hiding the message among irrelevant data
- To Confuse the cryptoanalyst

Big rumble in New Guinea.
The war on
celebrity acts should end soon.
Over four
big ecstatic elephants replicated.

Steganography: AN Example

- Hiding the message among irrelevant data
- To Confuse the cryptoanalyst

Big rumble in New Guinea.
The war on
celebrity acts should end soon.
Over four
big ecstatic elephants replicated.

Bring two cases of beer.

The Objectives of Cryptography

Fundamental tasks of cryptography:

It is to provide confidentiality by encryption methods.

The message to be transmitted {it can be some text, numerical data, an executable program or any other kind of information} is called the plaintext.

Alice encrypts the plaintext m and obtains the ciphertext c. The ciphertext c is transmitted to Bob. Bob turns the ciphertext back into the plaintext by decryption. To decrypt, Bob needs some secret information, a secret decryption key.

Say an adversary Eve still may intercept the ciphertext. However, the encryption should guarantee secrecy and prevent her from deriving any information about the plaintext from the observed ciphertext.

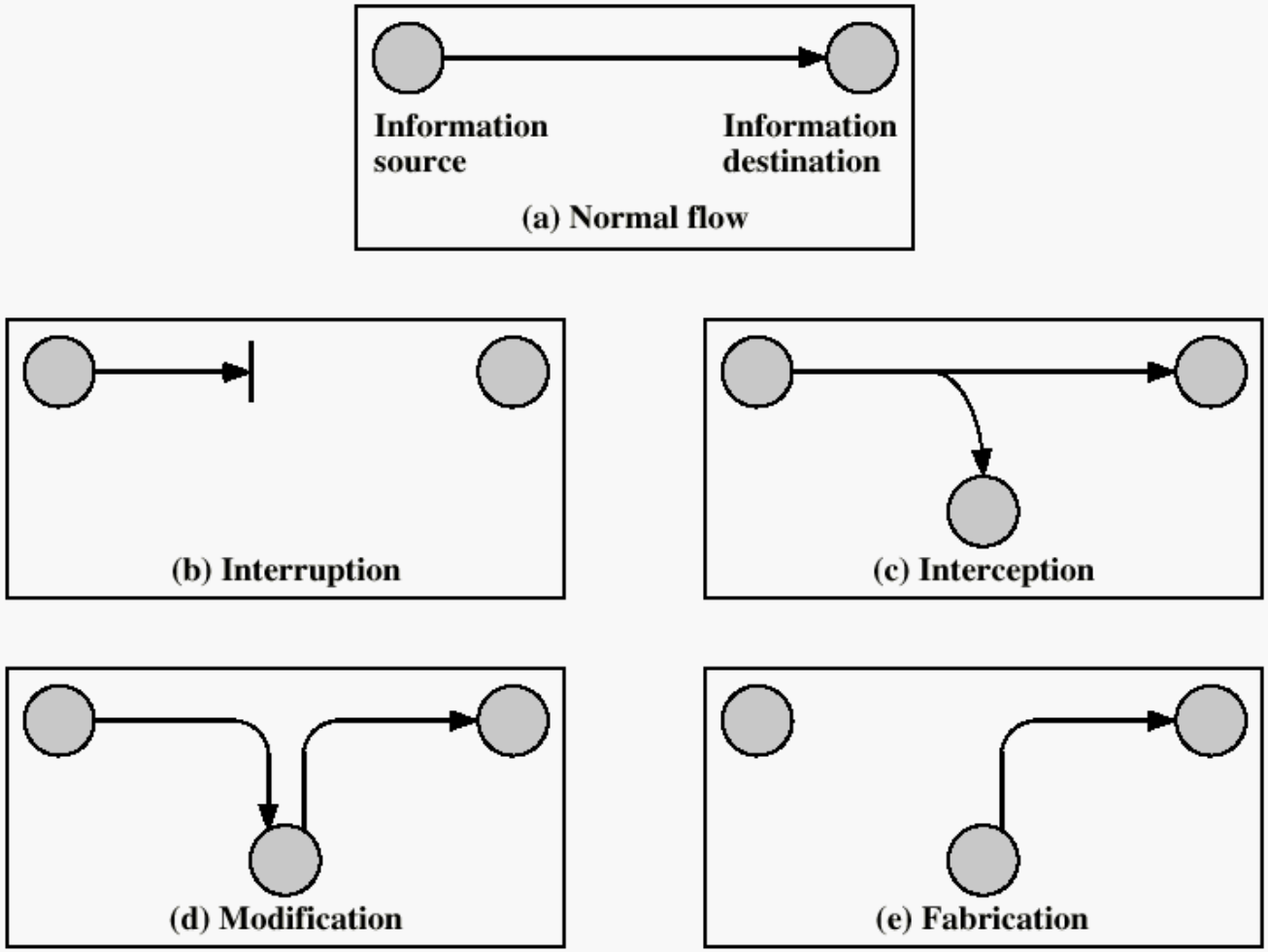


Figure 1.1 Security Threats

The Objectives of Cryptography

Providing confidentiality is not the only objective of cryptography. Cryptography is also used to provide solutions for other problems:

1. Data integrity: The receiver of a message should be able to check whether the message was modified during transmission, either accidentally or deliberately. No one should be able to substitute a false message for the original message, or for parts of it.

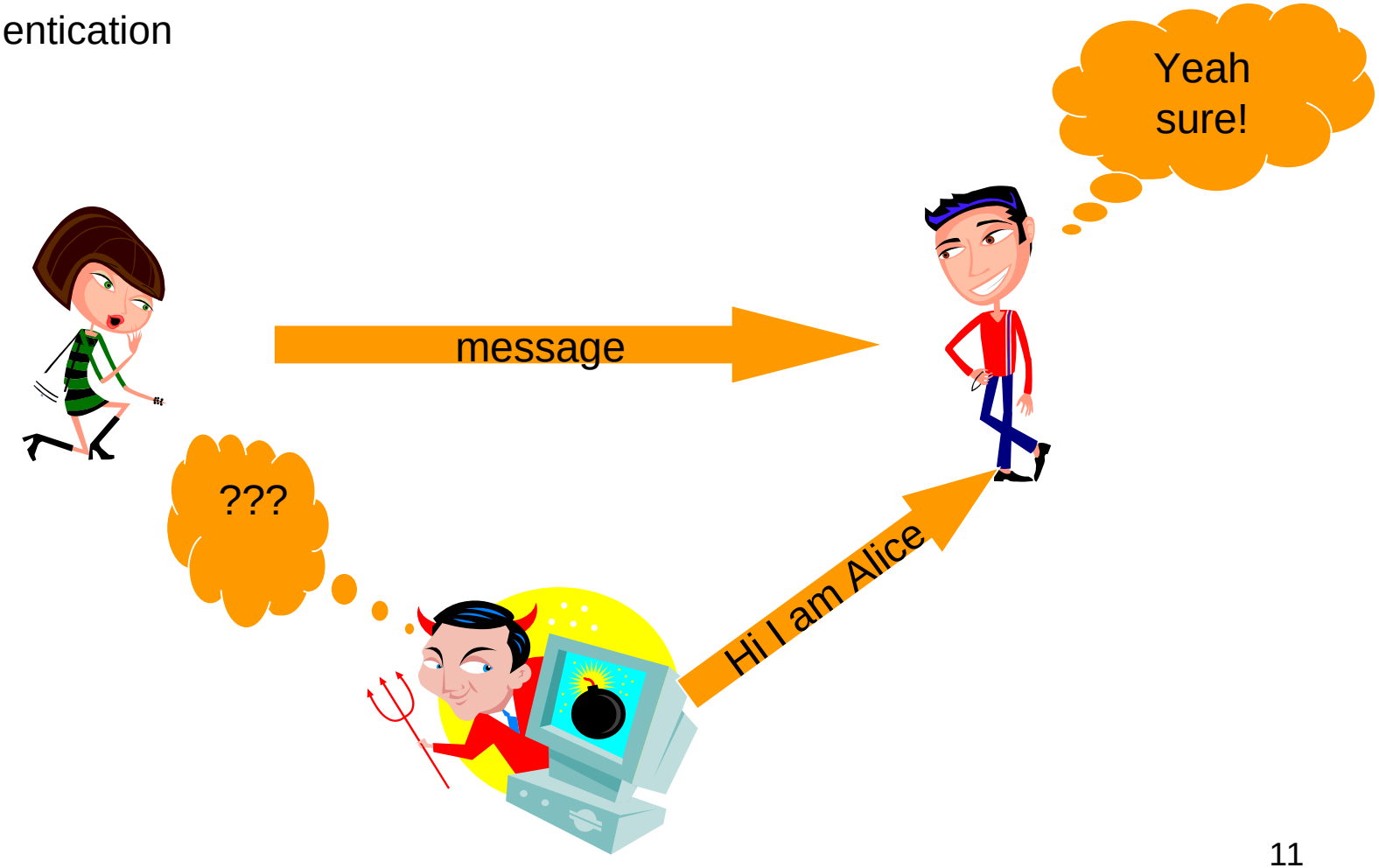
2. Authentication: The receiver of a message should be able to verify its origin. No one should be able to send a message to Bob and pretend to be Alice (data origin authentication). When initiating a communication, Alice and Bob should be able to identify each other (entity authentication).

Access control is a data security process that enables organizations to manage who is authorized to access corporate data and resources. Secure access control uses policies that verify users are who they claim to be and ensures appropriate control access levels are granted to users.

3. Non-repudiation: The sender should not be able to later deny that she sent a message.

The Objectives of Cryptography

- The science of communication in the presence of an adversary
  - Encryption
  - Authentication



Attacks

Basically, an attack on a cryptosystem is any method that starts with some information about the plaintext and the corresponding ciphertext, enciphered under a key, which is yet unknown to the cryptanalyst. Determining the key and thus the plaintext in its entirety is the end goal.
There are two major classes of attacks:

Passive:

Where the cryptanalyst monitors the channels of communications, thereby only *threatening* confidentiality of data.

Active:

Where the cryptanalyst attempts to add, delete, or somehow alter the message, threatening not only confidentiality but also integrity and authentication of data.

Passive attacks may be further subdivided into six classes:

(a) Chosen-plaintext: With this attack the cryptanalyst chooses plaintext, is then given corresponding ciphertext, and analyzes the data to determine the enciphering key to obtain plaintext from previously unseen ciphertext.

Attacks

(b) ***Chosen-ciphertext:*** In this form of attack the cryptanalyst chooses the ciphertext and is given the corresponding plaintext. Of course, given the required data, by their very nature such attacks are difficult to mount. For example, one way to mount a chosen-ciphertext attack is to gain access to the equipment used to encipher, as was the case, for instance, with the Americans gaining access to the Japanese cipher machines prior to World War II. Then the cryptanalyst can use such equipment to deduce plaintext from other intercepted ciphertext, since the equipment does not give the cryptanalyst the decryption key.

(c) ***Known-plaintext:*** This attack is more practical than chosen-plaintext since the cryptanalyst has some amount of both plaintext and corresponding ciphertext. Even a small amount of information in this type of attack may suffice to find the key. This type of attack was useful against the German Enigma machine in World War II, for instance.

(d) ***Ciphertext-only:*** Even more practical than the latter is this attack, wherein the cryptanalyst has only the ciphertext as data to deduce the key and subsequent plaintext. Any cryptosystem that is vulnerable to this type of attack is completely insecure.

Attacks

Brute-Force Attacks

In this type of attack, also called an *exhaustive serach of the keyspace*, all possible keys are tried to determine which one is being used by communicating parties. For a well-designed cryptosystem, this type of attack is too time consuming to undertake.

Ex. DES symmetric Crypto algorithm takes input of 56 bits. So, $2^{56} = 7.2 \times 10^{16}$. Due to short key length DES has been broken in less than 24 hours.

But assume that key space is 10^{30} then if computer does 10^{9} calculations per second then 3×10^{7}per year so it will take more than 3×10^{13} years which is more than age of universe.

Attacks

Brute-Force Attacks vs Other attacks

Quantum computing attack

Algorithmic attacks

Hardware attack

Side channel attack

Dictionary attack

Protocol based attack

Timing/Power consumption

Mathematical attacks etc

Orange book Standard

Five Types of Security

1. Critical infrastructure security.
2. Application security.
3. Network security.
4. Cloud security.
5. Internet of Things (IoT) security.

Trusted Computer System Evaluation Criteria (TCSEC) is a United States Government Department of Defense (DoD) standard that sets basic requirements for assessing the effectiveness of computer security controls built into a computer system. The TCSEC was used to evaluate, classify, and select computer systems being considered for the processing, storage, and retrieval of sensitive or classified information.

The TCSEC, frequently referred to as the **Orange Book** which Describes the security design and subsequent evaluation of security for an information system.

Orange book Standard

Fundamental objectives and requirements

Mandatory Security Policy – Enforces access control rules based directly on an individual's clearance, authorization for the information and the confidentiality level of the information being sought. Other indirect factors are physical and environmental. This policy must also accurately reflect the laws, general policies and other relevant guidance from which the rules are derived.

Accountability
Individual accountability regardless of policy must be enforced. A secure means must exist to ensure the access of an authorized and competent agent that can then evaluate the accountability information within a reasonable amount of time and without undue difficulty.

The accountability objective includes three requirements:
Identification – The process used to recognize an individual user.
Authentication – The verification of an individual user's authorization to specific categories of information.
Auditing – Audit information must be selectively kept and protected so that actions affecting security can be traced to the authenticated individual.

Orange book Standard

Fundamental objectives and requirements

Assurance

The computer system must contain hardware/software mechanisms that can be independently evaluated to provide sufficient assurance that the system enforces the above requirements.

Assurance Mechanisms

Operational Assurance: System Architecture, System Integrity, Covert Channel Analysis, Trusted Facility Management, and Trusted Recovery

Life-cycle Assurance : Security Testing, Design Specification and Verification, Configuration Management, and Trusted System Distribution

Continuous Protection Assurance – The trusted mechanisms that enforce these basic requirements must be continuously protected against tampering or unauthorized changes.

Orange book Standard

Stack and Buffer overflow

A **buffer** is a temporary area for data storage. When more data (than was originally allocated to be stored) gets placed by a program or system process, the extra data overflows. It causes some of that data to leak out into other buffers, which can corrupt or overwrite whatever data they were holding.

In a **buffer-overflow attack,** the extra data sometimes holds specific instructions for actions intended by a hacker or malicious user; for example, the data could trigger a response that damages files, changes data or unveils private information.

Attacker would use a buffer-overflow exploit to take advantage of a program that is waiting on a user's input.

Stack-based buffer overflows, which are more common among attackers, exploit applications and programs by using what is known as a stack memory space used to store user input.

Orange book Standard

Stack and Buffer overflow

Modern compilers normally provide overflow checking option during the compile/link time but during the run time. it is quite difficult to check this problem without any extra protection mechanism such as using exception handling.

```
// A C program to demonstrate buffer overflow
#include <stdio.h>
#include <string.h>
#include <stdlib.h>


int main(int argc, char *argv[])
{

   // Reserve 5 byte of buffer plus the terminating NULL.
   // should allocate 8 bytes = 2 double words,
   // To overflow, need more than 8 bytes...
   char buffer[5];  // If more than 8 characters input
           // by user, there will be access
           // violation, segmentation fault


   // a prompt how to execute the program...
   if (argc < 2)
   {
      printf("strcpy() NOT executed....\n");
      printf("Syntax: %s <characters>\n", argv[0]);
      exit(0);
   }
```

```
   // copy the user input to mybuffer, without any
      // bound checking a secure version is strcpy_s(
      strcpy(buffer, argv[1]);
      printf("buffer content= %s\n", buffer);


      // you may want to try strcpy_s()
      printf("strcpy() executed...\n");

      return 0;  }
```

Compile this program in Linux and for output use command output_file INPUT

Stack and Buffer overflow

```
Input : 12345678 (8 bytes), the program run smoothly.

Input : 123456789 (9 bytes) "Segmentation fault" message will be displayed and the program terminat
```

The vulnerability exists because the buffer could be overflowed if the user input (argv[1]) bigger than 8 bytes. Why 8 bytes? For 32 bit (4 bytes) system, we must fill up a double word (32 bits) memory. Character (char) size is 1 byte, so if we request buffer with 5 bytes, the system will allocate 2 double words (8 bytes). That is why when you input more than 8 bytes; the mybuffer will be over flowed.

Similar standard functions that are technically less vulnerable, such as strncpy(), strncat(), and memcpy(), do exist. But the problem with these functions is that it is the programmer responsibility to assert the size of the buffer, not the compiler.

Every C/C++ coder or programmer must know the buffer overflow problem before they do the coding. A lot of bugs generated, in most cases can be exploited as a result of buffer overflow.

Thank You